

- **Expediente N.º: EXP202209077**

RESOLUCIÓN DE PROCEDIMIENTO SANCIONADOR

Del procedimiento instruido por la Agencia Española de Protección de Datos y en base a los siguientes

ANTECEDENTES

PRIMERO: En fecha 15 de julio de 2022, **D. A.A.A.** (en adelante, el reclamante), interpuso reclamación ante la Agencia Española de Protección de Datos. La reclamación se dirige contra ALL ABOUT WATER, S.L. con NIF B42542290 (en adelante AAW o la reclamada). Los motivos en que basa la reclamación son los siguientes:

El reclamante presentó una reclamación al responsable del sitio web thebath.es, relacionada con un producto adquirido a través de este. Su reclamación, identificada con el número *****RECLAMACIÓN.1**, fue cerrada y vinculada a otra identificada con el número *****RECLAMACIÓN.2**, asociada a otro pedido realizado por un tercero. Esto, según la documentación aportada por el reclamante, supuso que el tercero tuviera acceso a los datos personales del reclamante, relacionados con el pedido realizado (nombre, apellidos, dirección completa y teléfono).

Junto a la notificación se aporta:

- Copia de las comunicaciones mantenidas con la entidad reclamada el día 15 de julio de 2022, relativas a una reclamación en relación con los productos adquiridos.

Incluye una comunicación remitida, el mismo día, desde la dirección de correo electrónico de la entidad reclamada (support@thebath.zendesk.com) y dirigida a un tercero, con copia al reclamante, que contiene un hilo en el que le informan, entre otros, de que la solicitud número *****RECLAMACIÓN.1** fue cerrada y fusionada con la solicitud número *****RECLAMACIÓN.2**. Este hilo contiene información del pedido realizado por el reclamante e incluye datos identificativos de este (nombre y apellidos) y de contacto (número de teléfono y dirección postal).

SEGUNDO: De conformidad con el artículo 65.4 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y Garantía de los Derechos Digitales (en adelante LOPDGDD), se dio traslado de dicha reclamación a la parte reclamada, para que procediese a su análisis e informase a esta Agencia en el plazo de un mes, de las acciones llevadas a cabo para adecuarse a los requisitos previstos en la normativa de protección de datos.

El traslado, que se practicó conforme a las normas establecidas en la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante, LPACAP), mediante notificación electrónica, fue recibido en

fecha 6 de septiembre de 2022, como consta en el certificado que obra en el expediente.

No se ha recibido respuesta a este escrito de traslado

TERCERO: En fecha 15 de octubre de 2022, de conformidad con el artículo 65 de la LOPDGDD, se admitió a trámite la reclamación presentada por la parte reclamante.

CUARTO: La Subdirección General de Inspección de Datos procedió a la realización de actuaciones previas de investigación para el esclarecimiento de los hechos en cuestión, en virtud de las funciones asignadas a las autoridades de control en el artículo 57.1 y de los poderes otorgados en el artículo 58.1 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), y de conformidad con lo establecido en el Título VII, Capítulo I, Sección segunda, de la LOPDGDD, teniendo conocimiento de los siguientes extremos:

Fecha en la que tuvieron lugar los hechos reclamados: 15 de julio de 2022.

La entidad reclamada ha sido requerida por la Inspección de Datos para que aporte información y documentación en relación con los hechos denunciados. Con fecha 7 de diciembre de 2022, tuvo entrada en esta Agencia un escrito de respuesta al requerimiento de información, en el que manifiesta lo siguiente:

- o La entidad dispone de un sistema para responder a los clientes mediante tickets; esos tickets se gestionan manualmente, y cuando un cliente envía varios emails diferentes, o varios mensajes por vías diferentes, el encargado de gestionarlos “fusiona” unos tickets y otros del mismo cliente para llevar un sólo hilo de conversación. En este caso concreto, esa fusión manual se hizo por error con el ticket de otro cliente, ya que la fusión se realiza con códigos, en este caso, un cambio de número supuso el error ocasionado.
- o No le consta haber recibido reclamaciones de otros clientes por estos hechos.
- o Aporta copia del histórico de la conversación con el cliente (aquí reclamante), en el que se comprueba que éste les comunica lo siguiente: *“Buenas tardes, no entiendo por qué han fusionado mi solicitud ***RECLAMACIÓN.1 del pedido (...) con esta otra que nada tiene que ver conmigo. Han dado por resuelta la otra y no puedo añadir ningún comentario... Mis datos personales que aparecen aquí han sido puestos a disposición de un tercero que nada tiene que ver con el caso y vulnera gravemente la ley de protección de datos. Ruego tomen acción de manera inmediata”*. Se comprueba que 11 minutos más tarde la entidad le responde lo siguiente: *“hemos procedido a solucionarlo. Lo sentimos. Un saludo”*.

Indica la reclamada que el mismo día 15 de julio, se procede a eliminar el CC (Con copia) de las comunicaciones para que ningún ticket más sea recibido por ambos usuarios.

- o No aporta, como se le requirió, información y documentación acreditativa sobre los controles y medidas de seguridad asociadas a la confidencialidad de la información dirigida a los empleados.
- o No aporta, como se le requirió, informe sobre las medidas técnicas y organizativas adoptadas para evitar que se produzcan incidencias similares, fechas de implantación y controles efectuados para comprobar su eficacia.
- o Respecto a las acciones llevadas a cabo con objeto de minimizar los efectos adversos de este incidente y las adoptadas para su resolución final, manifiesta que se ha notificado a los encargados de la gestión de dichos tickets sobre el error cometido, para que en futuras ocasiones tengan mucho más cuidado con cualquier fusión, aunque no se aporta documentación que lo acredite. Alega que en ningún caso ha ocurrido esto anteriormente, ni tampoco después de estos hechos y que se trata de un indecente completamente aislado debido a un error humano.

La entidad reclamada fue requerida nuevamente por la Inspección de Datos, en fecha 24 de marzo de 2023, para que aportara información y documentación acreditativa sobre los controles y medidas de seguridad asociadas a la confidencialidad de la información, dirigida a los empleados e informara sobre las medidas técnicas y organizativas adoptadas para evitar que se produzcan incidencias similares, fechas de implantación y controles efectuados para comprobar su eficacia, sin que se haya recibido respuesta.

QUINTO: De acuerdo con el informe recogido de la herramienta AXESOR, la entidad ALL ABOUT WATER, S.L. es una empresa constituida en el año 2017, con un volumen de negocios de (...), en el ejercicio 2021.

SEXTO: En fecha 6 de octubre de 2023, la Directora de la Agencia Española de Protección de Datos acordó iniciar procedimiento sancionador a la parte reclamada, con arreglo a lo dispuesto en los artículos 63 y 64 de la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante, LPACAP), por la presunta infracción del artículo 5.1.f) del RGPD, tipificada en el artículo 83.5 del RGPD y por la presunta infracción del artículo 32 del RGPD, tipificada en el artículo 83.4 del RGPD.

El acuerdo de inicio fue enviado, conforme a las normas establecidas en la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante, LPACAP), mediante notificación electrónica, siendo recibido en fecha 6 de octubre de 2023, como consta en el certificado que obra en el expediente.

SÉPTIMO: Notificado el citado acuerdo de inicio conforme a las normas establecidas en la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante, LPACAP), la parte reclamada presentó escrito de alegaciones en el que, en síntesis, manifestaba que, efectivamente ese hecho se produjo, no tardando más de ONCE minutos en tomar medidas para salvaguardar los datos de su cliente. Afirma que cuenta con un documento de seguridad, en materia de

protección de datos, que garantiza los derechos, así como la protección de los datos con los que trata, para poder otorgar sus servicios a sus clientes y garantizar el buen uso de los datos personales.

Para acreditar lo manifestado, expone que procede a adjuntar la siguiente documentación:

- DOC.1 Política de protección de datos
- DOC.2 Registro de Actividades de Tratamiento
- DOC. 3 Cláusula informativa
- DOC. 4 Cláusula informativa básica
- DOC. 5 Cláusula informativa detallada
- DOC. 6 Normas Uso Empleados
- DOC. 7 Decálogo Personal
- DOC. 8 Política de mesas limpias
- DOC. 9 Política de impresoras
- DOC. 10 Política de destructoras
- DOC. 11 Política interna de desconexión digital en el ámbito laboral
- DOC. 12 Gestión de violaciones de Seguridad
- DOC. 13 Política de notificación de violaciones de Seguridad
- DOC. 14 Buenas prácticas en la gestión de contraseñas

Manifiesta que de dicha documentación se pueden observar las medidas llevadas a cabo por parte de la empresa con la intención de subsanar el error cometido, tanto de manera interna como con el personal de esta, garantizando así el cumplimiento de del RGPD.

Por último, indica que la brecha de seguridad que se generó se notificó a la Agencia y se procedió a tomar medidas para que no se repitiera el incidente, circunstancia que afirma que se puede comprobar de la documental aportada.

Por todo lo anteriormente expuesto, solicita el archivo del inicio del expediente sancionador por cumplir con los requisitos establecidos en el RGPD.

OCTAVO: En fecha 11 de julio de 2024, la Directora de la Agencia Española de Protección de Datos, en relación con el procedimiento sancionador nº EXP202209077 incoado por esta Agencia a ALL ABOUT WATER, S.L., de acuerdo con las facultades conferidas en la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante, LPACAP), acordó nombrar Instructora del procedimiento a **B.B.B.**, en sustitución de **C.C.C.**, con indicación de que podría ser recusado, en su caso, en cualquier momento de la tramitación del procedimiento, conforme a lo establecido en el artículo 24 de la Ley 40/2015, de 1 de octubre, de Régimen Jurídico del Sector Público (LRJSP).

Dicho acuerdo fue enviado, conforme a las normas establecidas en la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante, LPACAP), mediante notificación electrónica, siendo recibido en fecha 12 de julio de 2024, como consta en el certificado que obra en el expediente.

NOVENO: En fecha 17 de julio de 2024, al no constar recibida parte de la documentación que manifiesta que aportaba, se le requirió para que, en un plazo de 5 días la aportase, con indicación de que, de no hacerlo, se proseguiría con la tramitación del procedimiento, conforme a lo dispuesto en el artículo 77 de la LPACAP.

Notificado el citado requerimiento conforme a las normas establecidas en la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante, LPACAP) y transcurrido el plazo otorgado, se ha constatado que no se ha recibido alegación alguna por la parte reclamada.

DÉCIMO: En fecha 27 de agosto de 2024, se formuló propuesta de resolución, proponiendo:

<< “Que por la Directora de la Agencia Española de Protección de Datos se sancione a ALL ABOUT WATER, S.L., con NIF B42542290,

- por la infracción del artículo 5.1.f) del RGPD, tipificada conforme a lo dispuesto en el artículo 83.5 del RGPD, calificada como muy grave a efectos de prescripción, en el artículo 72.1 a) de la LOPDGDD, con una multa de 5.000 euros.

- por la infracción del artículo 32 del RGPD, tipificada conforme a lo dispuesto en el artículo 83.4 del RGPD, calificada como grave a efectos de prescripción, en el artículo 73 f) de la LOPDGDD, con una multa de 3.000 euros.

Que por la Directora de la Agencia Española de Protección de Datos se ordene a ALL ABOUT WATER, S.L., con NIF B42542290, que en virtud del artículo 58.2.d) del RGPD, implante, en el plazo de un mes, las medidas correctoras necesarias para adecuar su actuación a la normativa de protección de datos personales, que impidan que en el futuro se repitan hechos similares, así como que informe a esta Agencia, en el mismo plazo, sobre las medidas adoptadas.” .>>

La citada propuesta de resolución fue enviada, conforme a las normas establecidas en la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante, LPACAP), mediante notificación electrónica,

siendo recibida en fecha 29 de agosto de 2024, como consta en el certificado que obra en el expediente.

UNDÉCIMO: En fecha 12 de septiembre de 2024, la entidad reclamada presentó escrito de alegaciones a la Propuesta de Resolución, en el que, en síntesis, adjunta la siguiente documentación:

- Cláusula informativa reducida para los interesados.
- Documento informativo sobre destrucción segura y confidencial de la información.
- Registro de Actividades de Tratamiento.
- Seguridad del tratamiento.
- Información en cumplimiento de la normativa de protección de datos personales.
- Documento de Política de Protección de Datos.
- Documento de Política de notificación y comunicación de las violaciones de la seguridad de los datos personales.

A la vista de todo lo actuado, por parte de la Agencia Española de Protección de Datos en el presente procedimiento se consideran hechos probados los siguientes,

HECHOS PROBADOS

PRIMERO: Consta comunicación remitida desde la dirección de correo electrónico de la entidad reclamada (support@thebath.zendesk.com) y dirigida a un tercero con copia al reclamante, que contiene un hilo en el que le informan, entre otros, de que la solicitud número *****RECLAMACIÓN.1** fue cerrada y fusionada en la solicitud número *****RECLAMACIÓN.2**. Este hilo contiene información del pedido realizado por el reclamante e incluye datos identificativos de este (nombre y apellidos) y de contacto (número de teléfono y dirección postal).

SEGUNDO: En fecha 15 de julio de 2022, consta que el reclamante les comunica lo siguiente:

*“Buenas tardes, no entiendo por qué han fusionado mi solicitud *****RECLAMACIÓN.1** del pedido (...) con esta otra que nada tiene que ver conmigo. Han dado por resuelta la otra y no puedo añadir ningún comentario... Mis datos personales que aparecen aquí han sido puestos a disposición de un tercero que nada tiene que ver con el caso y vulnera gravemente la ley de protección de datos. Ruego tomen acción de manera inmediata”.*

TERCERO: Se comprueba que 11 minutos más tarde la entidad le responde lo siguiente:

“hemos procedido a solucionarlo. Lo sentimos. Un saludo”.

CUARTO: La parte reclamada indica que el mismo día 15 de julio, procedió a eliminar el CC (Con Copia) de las comunicaciones para que ningún ticket fuera recibido por ambos usuarios.

QUINTO: La parte reclamada presenta escrito de alegaciones en el que reconoce que se produjo el incidente y que no tardó más de once minutos en tomar medidas para salvaguardar los datos de su cliente.

FUNDAMENTOS DE DERECHO

I

Competencia

De acuerdo con los poderes que el artículo 58.2 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), otorga a cada autoridad de control y según lo establecido en los artículos 47, 48.1, 64.2 y 68.1 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y Garantía de los Derechos Digitales (en adelante, LOPDGDD), es competente para iniciar y resolver este procedimiento, la Directora de la Agencia Española de Protección de Datos.

Asimismo, el artículo 63.2 de la LOPDGDD determina que: *“Los procedimientos tramitados por la Agencia Española de Protección de Datos se regirán por lo dispuesto en el Reglamento (UE) 2016/679, en la presente ley orgánica, por las disposiciones reglamentarias dictadas en su desarrollo y, en cuanto no las contradigan, con carácter subsidiario, por las normas generales sobre los procedimientos administrativos.”*

II

Cuestiones previas

En el presente caso, de acuerdo con lo establecido en el artículo 4.1 del RGPD, consta la realización de un tratamiento de datos personales, toda vez que la reclamada realiza, entre otros tratamientos, la recogida, registro, conservación, utilización, acceso, supresión de datos personales de personas físicas, tales como: nombre y apellidos, N.I.F, dirección postal, número de teléfono, dirección de correo electrónico, etc.

La reclamada realiza esta actividad en su condición de responsable del tratamiento, dado que es quien determina los fines y medios de tal actividad, en virtud del artículo 4.7 del RGPD.

El artículo 4 apartado 12 del RGPD define, de un modo amplio, las *“violaciones de seguridad de los datos personales”* (en adelante brecha de datos personales) como *“todas aquellas violaciones de la seguridad que ocasionen la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos.”*

En el presente caso, consta una brecha de datos personales en las circunstancias arriba indicadas, categorizada como una brecha de confidencialidad al haberse expuesto a un tercero no autorizado datos personales del reclamante.

Dentro de los principios del tratamiento previstos en el artículo 5 del RGPD, la integridad y confidencialidad de los datos personales se garantiza en el apartado 1.f) del citado artículo. Por su parte, la seguridad de los datos personales viene regulada en el artículo 32 del RGPD, que reglamenta la seguridad del tratamiento.

III

Alegaciones al Acuerdo de inicio

En respuesta a las alegaciones presentadas por la entidad reclamada se debe señalar lo siguiente:

Alega la entidad reclamada que de la documentación aportada se pueden observar las medidas llevadas a cabo con la intención de subsanar el error cometido, tanto de manera interna como con el personal, garantizando así el cumplimiento del RGPD. Detalla a continuación la documentación que adjunta.

Analizada la documentación, cabe reseñar que no consta recibida parte de la documentación que manifiesta que aporta en su escrito de alegaciones, y la que aporta, no acredita los controles y medidas de seguridad asociadas a la confidencialidad de la información dirigida a los empleados. Tampoco consta informe sobre las medidas técnicas y organizativas adoptadas para evitar que se produzcan incidencias similares, fechas de implantación y controles efectuados para comprobar su eficacia. Por último, tampoco consta la notificación de la brecha de datos personales a esta Agencia.

Es evidente que la mera mención de dicha documentación no constituye ni acredita la implantación de dichas medidas.

Sorprende a este Organismo que nada se haya aportado hasta la fecha a pesar de los requerimientos efectuados tanto en el transcurso de las actuaciones previas como en fase de alegaciones.

En consecuencia, lo aportado permite afirmar que existe una deficiencia en el cumplimiento de las obligaciones proactivas que la vigente normativa de protección de datos exige al responsable del tratamiento. Y es que el principio de responsabilidad proactiva constituye el eje central del RGPD y requiere para su cumplimiento, una actitud consciente, diligente y continua por parte de las entidades. Dicha actitud no se basa únicamente en reaccionar cuando algo ocurre, sino que exige ir siempre por delante, por lo que, de forma preventiva, se han de implantar las medidas de seguridad y controles dirigidas a garantizar la privacidad de los datos personales. Y demostrar su cumplimiento, cuestión que no ha quedado acreditada.

De la instrucción del procedimiento, tal y como se infiere de los Hechos Probados, se ha constatado que las medidas de seguridad que disponía implantadas la parte reclamada en relación con los datos que sometía a tratamiento en calidad de responsable, no eran las adecuadas al momento de producirse la quiebra de seguridad de datos personales, concretamente respecto del proceso de tramitación de

las reclamaciones de los clientes, puesto que lo realiza a través de un proceso manual y en el que, según sus manifestaciones, no es inusual que los clientes manden mensajes por distintas vías provocando la generación de diferentes tickets en relación con una misma reclamación, procediendo el encargado a *fusionarlos y llevarlos en un solo hilo de conversación*, siendo este sistema susceptible de incurrir en errores, tal y como se ha puesto de manifiesto en el caso que nos ocupa y que ha conllevado una vulneración de la confidencialidad de datos personales.

Es evidente que la implantación de medidas de seguridad podría ayudar a prevenir, en un futuro, incidentes como el que se sustancia en el presente procedimiento y mejoraría la calidad del proceso de tramitación de las reclamaciones. Por tanto, la inexistencia de un sistema más seguro en el proceso de gestión de las reclamaciones post venta, denota la insuficiencia de las medidas técnicas y organizativas razonables en función de los posibles riesgos estimados.

En cualquier caso, el error que alega la parte reclamada haber cometido no excluye su responsabilidad, puesto que, según reiterada jurisprudencia, no puede estimarse la existencia de tal error cuando éste es imputable a quien lo padece o pudo ser evitado con el empleo de una mayor diligencia. En este caso, el supuesto error es incompatible con la diligencia que la entidad viene obligada a observar, ya que las medidas de seguridad deben adoptarse en atención a todos y cada uno de los riesgos presentes en un tratamiento de datos de carácter personal, incluyendo entre los mismos, el factor humano.

Por otro lado, tampoco puede aceptarse la alegación relativa a que no tardó más de once minutos en tomar medidas para salvaguardar los datos de su cliente, toda vez que el correo fue enviado a un tercero y las medidas posteriores no eliminaron los riesgos producidos a la protección de datos del reclamante, ya que los datos ya habían sido enviados y es ahí cuando se materializó la pérdida de control de los propios datos personales, al perder el reclamante el poder de disposición sobre ellos.

En consecuencia, las alegaciones deben ser desestimadas, significándose que las argumentaciones presentadas no desvirtúan el contenido esencial de la infracción que se declara cometida ni suponen causa de justificación o exculpación suficiente.

IV

Alegaciones a la Propuesta de resolución

En respuesta a las alegaciones presentadas por la entidad reclamada se debe señalar lo siguiente:

Analizadas las alegaciones presentadas, se comprueba que ni de la documentación aportada por la entidad reclamada, ni de la interpretación del contenido de esta, deriva la aparición de ninguna circunstancia que pudiera desvirtuar el contenido esencial de las infracciones que se declaran cometidas, toda vez que siguen sin acreditarse los controles y medidas de seguridad asociadas a la confidencialidad de la información dirigida a los empleados. Tampoco consta informe sobre las medidas técnicas y organizativas adoptadas para evitar que se produzcan incidencias similares, fechas de implantación y controles efectuados para comprobar su eficacia.

Como ya se indicó en la respuesta dada por esta Agencia a las alegaciones presentadas al Acuerdo de inicio, la documentación aportada no constituye ni acredita la implantación de dichas medidas.

Por tanto, procede remitirse a la respuesta dada por esta Agencia que aparece transcrita en el Fundamento de Derecho III de la presente Resolución.

V

Obligación incumplida

El artículo 5.1.f) *“Principios relativos al tratamiento”* del RGPD establece:

“1. Los datos personales serán:

(...)

f) tratados de tal manera que se garantice una seguridad adecuada de los datos personales, incluida la protección contra el tratamiento no autorizado o ilícito y contra su pérdida, destrucción o daño accidental, mediante la aplicación de medidas técnicas u organizativas apropiadas («integridad y confidencialidad»).”

En el presente caso, consta que los datos personales de la parte reclamante fueron indebidamente expuestos a un tercero, al fusionarse la reclamación del cliente (aquí reclamante) con la de otro cliente, lo que ocasionó que ese otro cliente recibiera copia de las comunicaciones mantenidas con el reclamante, las cuales incluían datos personales suyos (nombre y apellidos, número de teléfono, dirección postal y correo electrónico).

En consecuencia, se considera que los hechos acreditados son constitutivos de una infracción, imputable a la parte reclamada, por vulneración del artículo 5.1.f) del RGPD.

VI

Tipificación y calificación de la infracción

La citada infracción del artículo 5.1.f) del RGPD supone la comisión de las infracciones tipificadas en el artículo 83.5 del RGPD, que bajo la rúbrica *“Condiciones generales para la imposición de multas administrativas”* dispone:

“Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 20 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 4 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

a) los principios básicos para el tratamiento, incluidas las condiciones para el consentimiento a tenor de los artículos 5, 6, 7 y 9; (...)”

A este respecto, la LOPDGDD, en su artículo 71 *“Infracciones”* establece que *“Constituyen infracciones los actos y conductas a las que se refieren los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679, así como las que resulten contrarias a la presente ley orgánica”*.

A efectos del plazo de prescripción, el artículo 72 *“Infracciones consideradas muy graves”* de la LOPDGDD indica:

“1. En función de lo que establece el artículo 83.5 del Reglamento (UE) 2016/679 se consideran muy graves y prescribirán a los tres años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:

a) El tratamiento de datos personales vulnerando los principios y garantías establecidos en el artículo 5 del Reglamento (UE) 2016/679. (...)”

VII Sanción

A efectos de fijar el importe de la sanción por infracción del artículo 5.1 f) del RGPD, procede graduar la multa con los criterios que establecen el artículo 83.2 del RGPD, teniendo en cuenta:

- Artículo 83.2.a) RGPD: Naturaleza, gravedad y duración de la infracción.

Se considera que la naturaleza de la infracción es grave puesto que acarrea una pérdida de confidencialidad y, por tanto, de disposición y control irremediable sobre los datos personales.

Asimismo, se considera que procede graduar la sanción a imponer de acuerdo con los siguientes criterios que establece el apartado 2 del artículo 76 “Sanciones y medidas correctivas” de la LOPDGDD:

Como agravantes:

- Artículo 76.2.b) LOPDGDD. Vinculación de la actividad del infractor con la realización de tratamientos de datos de carácter personal: La reclamada se dedica a la venta *on line* a través de internet de productos al por menor (saneamientos, fontanería y mobiliario para el baño), siendo necesario, por tanto, el tratamiento continuo de datos personales de sus clientes.

Considerando los factores expuestos, la valoración que alcanza la cuantía de la multa es de 5.000 (cinco mil euros), por infracción del artículo 5.1 f) del RGPD.

VIII Obligación incumplida

El artículo 32 *“Seguridad del tratamiento”* del RGPD establece:

“1. Teniendo en cuenta el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas, el responsable y el encargado del tratamiento aplicarán medidas técnicas y

organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, que en su caso incluya, entre otros:

- a) la seudonimización y el cifrado de datos personales;
- b) la capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento;
- c) la capacidad de restaurar la disponibilidad y el acceso a los datos personales de forma rápida en caso de incidente físico o técnico;
- d) un proceso de verificación, evaluación y valoración regulares de la eficacia de las medidas técnicas y organizativas para garantizar la seguridad del tratamiento.

2. Al evaluar la adecuación del nivel de seguridad se tendrán particularmente en cuenta los riesgos que presente el tratamiento de datos, en particular como consecuencia de la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos.

3. La adhesión a un código de conducta aprobado a tenor del artículo 40 o a un mecanismo de certificación aprobado a tenor del artículo 42 podrá servir de elemento para demostrar el cumplimiento de los requisitos establecidos en el apartado 1 del presente artículo.

4. El responsable y el encargado del tratamiento tomarán medidas para garantizar que cualquier persona que actúe bajo la autoridad del responsable o del encargado y tenga acceso a datos personales solo pueda tratar dichos datos siguiendo instrucciones del responsable, salvo que esté obligada a ello en virtud del Derecho de la Unión o de los Estados miembros". (el subrayado es nuestro)

Hay que señalar que el RGPD en el citado precepto no establece un listado de las medidas de seguridad que sean de aplicación de acuerdo con los datos que son objeto de tratamiento, sino que establece que el responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas que sean adecuadas al riesgo que conlleve el tratamiento, teniendo en cuenta el estado de la técnica, los costes de aplicación, la naturaleza, alcance, contexto y finalidades del tratamiento, los riesgos de probabilidad y gravedad para los derechos y libertades de las personas interesadas.

Asimismo, las medidas de seguridad deben resultar adecuadas y proporcionadas al riesgo detectado, señalando que la determinación de las medidas técnicas y organizativas deberá realizarse teniendo en cuenta: la seudonimización y el cifrado, la capacidad para garantizar la confidencialidad, integridad, disponibilidad y resiliencia, la capacidad para restaurar la disponibilidad y acceso a datos tras un incidente, proceso de verificación (que no auditoría), evaluación y valoración de la eficacia de las medidas.

En todo caso, al evaluar la adecuación del nivel de seguridad se tendrán particularmente en cuenta los riesgos que presente el tratamiento de datos, como consecuencia de la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos y que pudieran ocasionar daños y perjuicios físicos, materiales o inmateriales.

En este mismo sentido el considerando 83 del RGPD señala que “(83) A fin de mantener la seguridad y evitar que el tratamiento infrinja lo dispuesto en el presente Reglamento, el responsable o el encargado deben evaluar los riesgos inherentes al tratamiento y aplicar medidas para mitigarlos, como el cifrado. Estas medidas deben garantizar un nivel de seguridad adecuado, incluida la confidencialidad, teniendo en cuenta el estado de la técnica y el coste de su aplicación con respecto a los riesgos y la naturaleza de los datos personales que deban protegerse. Al evaluar el riesgo en relación con la seguridad de los datos, se deben tener en cuenta los riesgos que se derivan del tratamiento de los datos personales, como la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos, susceptibles en particular de ocasionar daños y perjuicios físicos, materiales o inmateriales”.

En el presente caso, AAW se dedica a la venta *on line* a través de internet de determinados productos, atendiendo de forma electrónica las reclamaciones que realicen los clientes, suponiendo todo ello un riesgo en el tratamiento de los datos personales que debe valorar y tener en cuenta.

Por tanto, debe poner especial diligencia en las medidas técnicas y organizativas para garantizar una adecuada seguridad en el tratamiento de datos personales, estableciendo procedimientos y medidas adecuadas para ello. Entre otras, establecer un sistema seguro en el proceso de gestión de las reclamaciones post venta.

Según manifiesta la propia reclamada, utiliza un sistema para responder a los clientes mediante tickets, los cuales se gestionan manualmente, y que cuando *un cliente envía varios emails diferentes, o varios mensajes por vías diferentes, el encargado de gestionarlos “fusiona” unos tickets y otros del mismo cliente para llevar un sólo hilo de conversación.*

Por tanto, en el momento de producirse la brecha, no cabe afirmar que la reclamada contase con las medidas de seguridad adecuadas en función de los posibles riesgos estimados para evitar el incidente, concretamente respecto del proceso de tramitación de las reclamaciones de los clientes, puesto que lo realiza a través de un proceso manual y en el que, según sus manifestaciones, no es inusual que los clientes manden mensajes por vías distintas provocando la generación de diferentes tickets en relación con una misma reclamación, procediendo el encargado a *fusionarlos y llevarlos en un solo hilo de conversación*, siendo este sistema susceptible de incurrir en errores, tal y como se ha puesto de manifiesto en el caso que nos ocupa y que ha posibilitado el acceso por un tercero a datos personales del reclamante.

La responsabilidad de la parte reclamada viene determinada, por tanto, por la quiebra de seguridad puesta de manifiesto en la reclamación y por la falta de acreditación suficiente, a través de la documentación aportada, de los controles y medidas de seguridad encaminadas a evitar incidentes como el ocurrido, ya que es responsable de tomar decisiones destinadas a implementar de manera efectiva las medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo.

En consecuencia, se considera que los hechos acreditados son constitutivos de una infracción, imputable a la parte reclamada, por vulneración del artículo 32 del RGPD.

IX

Tipificación y calificación de la infracción

La citada infracción del artículo 32 del RGPD supone la comisión de las infracciones tipificadas en el artículo 83.4 del RGPD que bajo la rúbrica “*Condiciones generales para la imposición de multas administrativas*” dispone:

“Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 10 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 2 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

a) las obligaciones del responsable y del encargado a tenor de los artículos 8, 11, 25 a 39, 42 y 43; (...)”

A este respecto, la LOPDGDD, en su artículo 71 “*Infracciones*” establece que “*Constituyen infracciones los actos y conductas a las que se refieren los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679, así como las que resulten contrarias a la presente ley orgánica*”.

A efectos del plazo de prescripción, el artículo 73 “*Infracciones consideradas graves*” de la LOPDGDD indica:

“En función de lo que establece el artículo 83.4 del Reglamento (UE) 2016/679 se consideran graves y prescribirán a los dos años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:

f) La falta de adopción de aquellas medidas técnicas y organizativas que resulten apropiadas para garantizar un nivel de seguridad adecuado al riesgo del tratamiento, en los términos exigidos por el artículo 32.1 del Reglamento (UE) 2016/679. (...)

X

Sanción

A efectos de fijar el importe de la sanción por infracción del artículo 32 del RGPD, procede graduar la multa con los criterios que establecen el artículo 83.2 del RGPD, teniendo en cuenta:

- Artículo 83.2.a) RGPD: Naturaleza, gravedad y duración de la infracción.

Se considera que la naturaleza de la infracción es grave puesto que supone que la reclamada no cuenta con medidas técnicas y organizativas adecuadas para garantizar un nivel de seguridad adecuado al riesgo, o bien, existentes estas, no han sido observadas o correctamente implementadas.

Asimismo, se considera que procede graduar la sanción a imponer de acuerdo con los

siguientes criterios que establece el apartado 2 del artículo 76 “Sanciones y medidas correctivas” de la LOPDGDD:

Como agravantes:

- Artículo 76.2.b) LOPDGDD. Vinculación de la actividad del infractor con la realización de tratamientos de datos de carácter personal: La reclamada se dedica a la venta *on line* a través de internet de productos al por menor (saneamientos, fontanería y mobiliario para el baño), siendo necesario, por tanto, el tratamiento continuo de datos personales de sus clientes.

Considerando los factores expuestos, la valoración que alcanza la cuantía de la multa es de 3.000 € (tres mil euros) por infracción del artículo 32 del RGPD.

XI

Adopción de medidas

En el texto de la resolución se establecen cuáles han sido las infracciones cometidas y los hechos que han dado lugar a la vulneración de la normativa de protección de datos, de lo que se infiere con claridad cuáles son las medidas a adoptar, sin perjuicio de que el tipo de procedimientos, mecanismos o instrumentos concretos para implementarlas corresponda a la parte sancionada, pues es el responsable del tratamiento quien conoce plenamente su organización y ha de decidir, en base a la responsabilidad proactiva y en enfoque de riesgos, cómo cumplir con el RGPD y la LOPDGDD.

En el presente caso, por la presente autoridad se procede a requerir al responsable para que, en el plazo de un mes, implante las medidas correctoras necesarias para adecuar su actuación a la normativa de protección de datos personales que impidan que en el futuro se repitan hechos similares, así como que informe a esta Agencia, en el mismo plazo, sobre las medidas adoptadas.

Se advierte que no atender la orden de adopción de medidas impuestas por este organismo en la resolución sancionadora podrá ser considerado como una infracción administrativa conforme a lo dispuesto en el RGPD, tipificada como infracción en su artículo 83.5 y 83.6, pudiendo motivar tal conducta la apertura de un ulterior procedimiento administrativo sancionador.

Por lo tanto, de acuerdo con la legislación aplicable y valorados los criterios de graduación de las sanciones cuya existencia ha quedado acreditada, la Directora de la Agencia Española de Protección de Datos RESUELVE:

PRIMERO: IMPONER a ALL ABOUT WATER, S.L., con NIF B42542290,

- por la infracción del artículo 5.1.f) del RGPD, tipificada conforme a lo dispuesto en el artículo 83.5 del RGPD, calificada como muy grave a efectos de prescripción, en el artículo 72.1 a) de la LOPDGDD, con una multa de 5.000 euros.

- por la infracción del artículo 32 del RGPD, tipificada conforme a lo dispuesto en el artículo 83.4 del RGPD, calificada como grave a efectos de prescripción, en el artículo 73 f) de la LOPDGDD, con una multa de 3.000 euros.

SEGUNDO: ORDENAR a ALL ABOUT WATER, S.L., con NIF B42542290, que en virtud del artículo 58.2.d) del RGPD, en el plazo de 1 mes, desde que la presente resolución sea firme y ejecutiva, acredite haber procedido a la implantación de las medidas correctoras necesarias para adecuar su actuación a la normativa de protección de datos personales, que impidan que en el futuro se repitan hechos similares, así como que informe a esta Agencia, en el mismo plazo, sobre las medidas adoptadas.

TERCERO: NOTIFICAR la presente resolución a ALL ABOUT WATER, S.L.

CUARTO: Esta resolución será ejecutiva una vez finalice el plazo para interponer el recurso potestativo de reposición (un mes a contar desde el día siguiente a la notificación de esta resolución) sin que el interesado haya hecho uso de esta facultad. Se advierte al sancionado que deberá hacer efectiva la sanción impuesta una vez que la presente resolución sea ejecutiva, de conformidad con lo dispuesto en el art. 98.1.b) de la ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante LPACAP), en el plazo de pago voluntario establecido en el art. 68 del Reglamento General de Recaudación, aprobado por Real Decreto 939/2005, de 29 de julio, en relación con el art. 62 de la Ley 58/2003, de 17 de diciembre, mediante su ingreso, indicando el NIF del sancionado y el número de procedimiento que figura en el encabezamiento de este documento, en la cuenta restringida nº **IBAN: ES00-0000-0000-0000-0000-0000 (BIC/Código SWIFT: CAIXESBBXXX)**, abierta a nombre de la Agencia Española de Protección de Datos en la entidad bancaria CAIXABANK, S.A.. En caso contrario, se procederá a su recaudación en período ejecutivo.

Recibida la notificación y una vez ejecutiva, si la fecha de ejecutividad se encuentra entre los días 1 y 15 de cada mes, ambos inclusive, el plazo para efectuar el pago voluntario será hasta el día 20 del mes siguiente o inmediato hábil posterior, y si se encuentra entre los días 16 y último de cada mes, ambos inclusive, el plazo del pago será hasta el 5 del segundo mes siguiente o inmediato hábil posterior.

De conformidad con lo establecido en el artículo 50 de la LOPDGDD, la presente Resolución se hará pública una vez haya sido notificada a los interesados.

Contra esta resolución, que pone fin a la vía administrativa conforme al art. 48.6 de la LOPDGDD, y de acuerdo con lo establecido en el artículo 123 de la LPACAP, los interesados podrán interponer, potestativamente, recurso de reposición ante la Directora de la Agencia Española de Protección de Datos en el plazo de un mes a contar desde el día siguiente a la notificación de esta resolución o directamente recurso contencioso administrativo ante la Sala de lo Contencioso-administrativo de la Audiencia Nacional, con arreglo a lo dispuesto en el artículo 25 y en el apartado 5 de la disposición adicional cuarta de la Ley 29/1998, de 13 de julio, reguladora de la Jurisdicción Contencioso-administrativa, en el plazo de dos meses a contar desde el día siguiente a la notificación de este acto, según lo previsto en el artículo 46.1 de la referida Ley.

Finalmente, se señala que conforme a lo previsto en el art. 90.3 a) de la LPACAP, se podrá suspender cautelarmente la resolución firme en vía administrativa si el interesado manifiesta su intención de interponer recurso contencioso-administrativo. De ser éste el caso, el interesado deberá comunicar formalmente este hecho mediante escrito dirigido a la Agencia Española de Protección de Datos, presentándolo a través del Registro Electrónico de la Agencia [<https://sedeagpd.gob.es/sede-electronica-web/>], o a través de alguno de los restantes registros previstos en el art. 16.4 de la citada Ley 39/2015, de 1 de octubre. También deberá trasladar a la Agencia la documentación que acredite la interposición efectiva del recurso contencioso-administrativo. Si la Agencia no tuviese conocimiento de la interposición del recurso contencioso-administrativo en el plazo de dos meses desde el día siguiente a la notificación de la presente resolución, daría por finalizada la suspensión cautelar.

938-16012024

Mar España Martí
Directora de la Agencia Española de Protección de Datos